DevSecOps 1,2,3: De la teoría a la práctica sin morir en el intento

Víctor Orozco

18 de agosto de 2025

Cloud native

La mayor mentira cloud native

Al migrar a tecnologías de nube más nuevas -e.g. Serverless, BaaS, Microservicios- las empresas alcanzarán escala automáticamente, es decir, soportaran más usuarios con menos dinero y lanzaran nuevas versiones más rápido.

Cloud native

Abordaje para construir sistemas informáticos modernos en entornos dinámicos, como nubes públicas y privadas.

- Sistemas reactivos
- 12 cloud native factors
- Cloud native design patterns
- Domain Driven Design
- Microservices chassis y/o service mesh
- Container orchestration, serverless, BaaS
- Cloud

Cloud native

- (Queremos) Sistemas reactivos
- (Con un abordaje de) 12 cloud native factors
- (Donde errores comunes y soluciones son descritos por) cloud native design patterns
- (Entonces dividimos el sistema mediante) Domain Driven Design
- (Creando los servicios con) Microservices chassis y/o service mesh
- (Ejecutando las cargas sobre)Container orchestration, FaaS, BaaS
- (Por lo que ejecutamos con facilidad sobre)Cloud

Los proyectos de migración Cloud Native, son en la vida real Macro-Proyectos

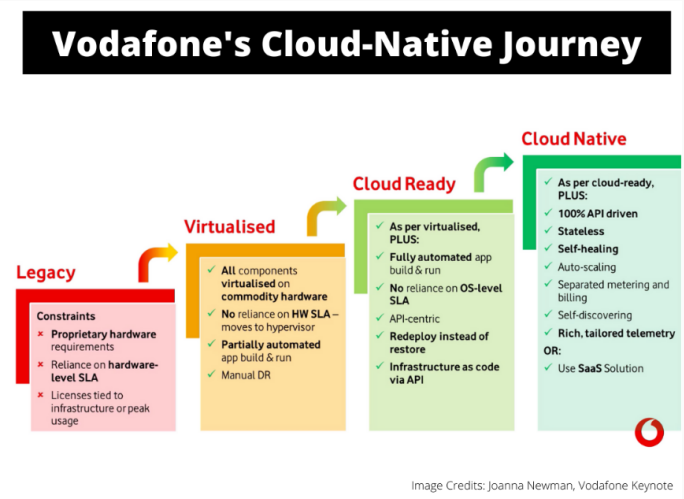
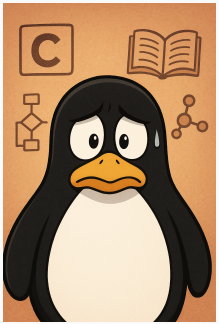


Image Credits: Joanna Newman, Vodafone Keynote

- Nuevo SDLC
- Automatización
- Operación

- Código Base - Workflow definido, despliegue multientorno
- Dependencias - Gestión y aislamiento
- Configuración - Externalización de parametros
- Servicios backend - Recursos acoplables
- Construir, Liberar, Ejecutar - CI/CD
- Procesos - Aplicaciones sin estado
- Asignación de Puertos - No depender de servidor, autoexponerse a través de la red
- Concurrencia - Escalar horizontalmente
- Descartabilidad - Iniciar y caer de forma rápida y segura
- Dev/Prod Paridad - Entornos lo más similares posibles
- Logs - Flujos de eventos hacia sistemas de agregación
- Procesos Admin - Operaciones administrativas idempotentes

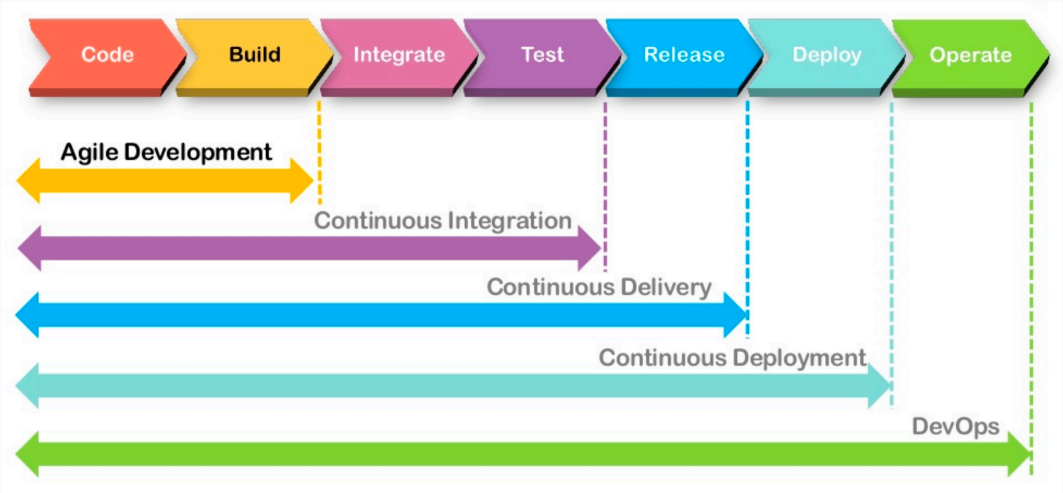
- Código Base - Gitflow, **Trunk Based**
- Dependencias - **Maven**, NPM
- Configuración - AWS SSM, HashiCorp Vault, Kubernetes Secrets
- Servicios backend - S3, RDS
- Construir, Liberar, Ejecutar - Jenkins, **Github Actions**
- Procesos - **Quarkus**, Node.js
- Asignación de Puertos - **Vert.x**, Undertow, Kestrel
- Concurrencia - AWS Lambda, **Kubernetes**, ECS, Fargate
- Descartabilidad - **Docker**, Knative
- Dev/Prod Paridad - **Terraform**, Pulumi, Cloudformation, Docker
- **Observabilidad** - **ServiceMonitors**, Opentelemetry, Cloudwatch, Grafana
- Procesos Admin - Flyway



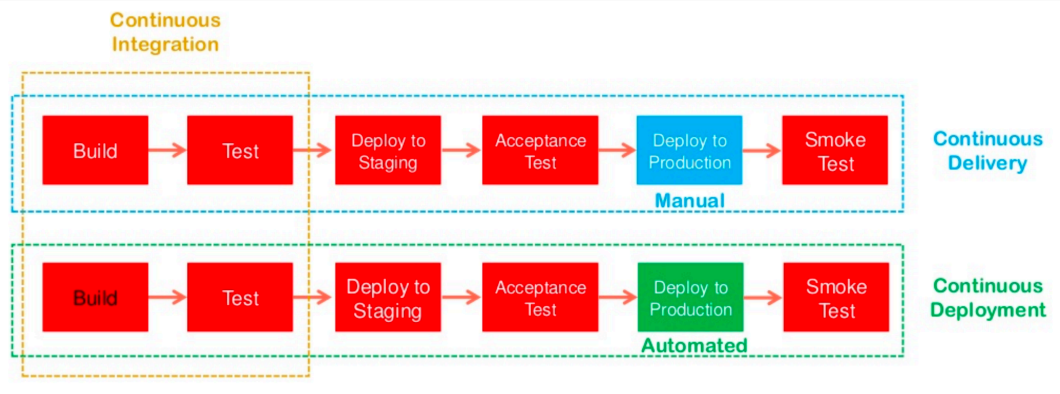
¿Y como controlo todo esto sin que me hackeen?

DevSecOps

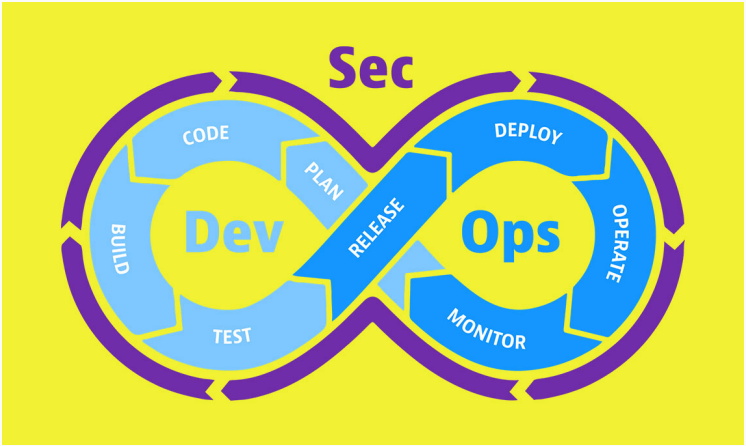
DevOps


Code
Build
Integrate
Test
Release
Deploy
Operate
Agile Development
Continuous Integration
Continuous Delivery
Continuous Deployment
DevOps

Delivery vs Deployment



DevSecOps



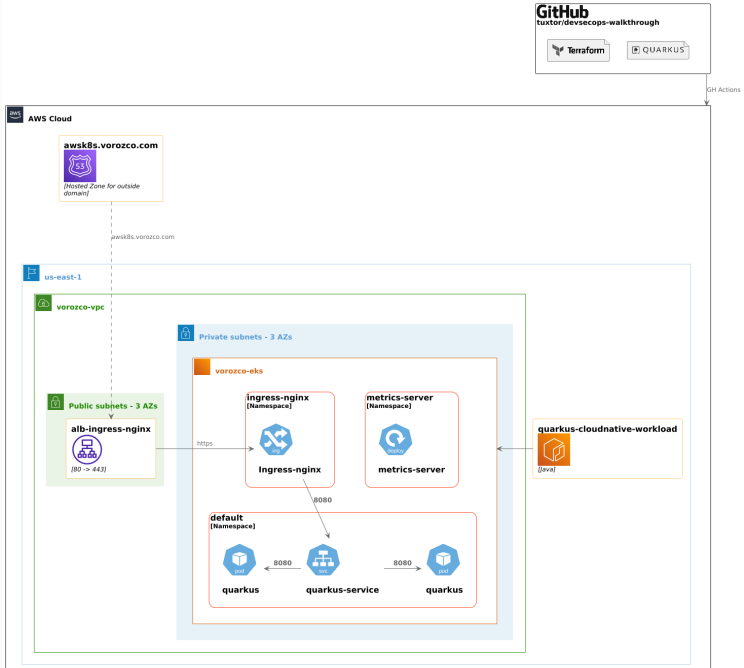
- Shift-Left
- Automatización de pruebas
- Security as code
- Cumplimiento
- Monitoreo y respuesta a incidentes

DevSecOps

- Shift-Left: Static Application Security Testing (Sonar, **Github Copilot**, **SpotBugs**), Software Composition Analysis (Snyk, Dependabot)
- Automatización de pruebas: DAST (OWASP ZAP) Container Security (AWS ECR Analysis, **Trivy**), IaC
- Security as code: Cultura, capacitación constante (KnowBe4)
- Gestión de secretos y cumplimiento: AWS SSM, HashiCorp Vault, ISO 27001, SOC2, RBAC
- Monitoreo y detección en tiempo real: AWS Shield, AWS WAF, Falco, Crowdstrike

Ejemplo

https://github.com/tuxtor/devsecops-walkthrough


GitHub
tuxtor/devsecops-walkthrough
Terraform
QUARKUS
GH Actions
AWS Cloud
awsk8s.vorozco.com
[Hosted Zone for outside domain]
awsk8s.vorozco.com
us-east-1
vorozco-vpc
Private subnets - 3 AZs
vorozco-eks
Public subnets - 3 AZs
alb-ingress-nginx
[80 -> 443]
https
ingress-nginx
[Namespace]
ingress-nginx
metrics-server
[Namespace]
metrics-server
quarkus-cloudnative-workload
[Java]
8080
default
[Namespace]
quarkus
8080
quarkus-service
8080
quarkus

¿Cómo hemos apoyado a otros clientes?

Servicios de Consultoría

- Implementación de infraestructura y pipelines CI/CD
- Diseño e implementación de arquitecturas cloud native seguras
- Desarrollo E2E y de arquetipos
- Capacitación especializada para equipos

Beneficios Clave

- Reducción de curva de aprendizaje
- Experiencia comprobada con proyectos alrededor del mundo
- Optimización de costos
- Conocimiento certificado

Transformemos juntos tu ciclo de desarrollo con seguridad integrada

Víctor Orozco





Oracle ACE Pro

Java Champions

ORACLE Certified Professional Java SE 8 Programmer

ORACLE Certified Associate Java SE 8 Programmer

CERTIFIED kubernetes ADMINISTRATOR

- me@vorozco.com
- @tuxtor
- https://vorozco.com
- https://tuxtor.shekalug.org

This work is licensed under Creative Commons Attribution-NonCommercial-ShareAlike 3.0 Guatemala (CC BY-NC-SA 3.0 GT).